

AI Security Architect

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 23: AI

1. The Role: Security as a Design Discipline

Most security roles in traditional IT are reactive — they detect, respond to, and remediate attacks on systems that were designed without security as a primary concern. The AI Security Architect role exists to change that pattern for AI systems: to ensure that security is designed in from the beginning rather than bolted on after deployment. This matters for AI systems in particular because AI has attack surfaces and failure modes that traditional security architecture does not address — adversarial inputs, training data poisoning, model extraction, membership inference, and supply chain attacks via model weight files are all categories that a traditional security architect may have no framework for analyzing.

The AI Security Architect is a relatively new, distinct role. Organizations that assign AI security responsibilities to practitioners with only traditional security architecture backgrounds frequently discover gaps when their first AI-focused red team engagement reveals attack surfaces that nobody on the security team had considered. SecAI+ tests candidates' understanding of what this role adds beyond general security architecture expertise.

2. NIST AI RMF and NIST CSF 2.0: The Framework Pair

AI Security Architects work within two complementary frameworks that the SecAI+ exam tests together. Understanding both frameworks and how they interact is essential.

Framework	Scope	AI Security Architect's Role
NIST AI RMF 1.0 — GOVERN	Establishing policies, accountability structures, and human oversight requirements for AI risk	Provides technical input; helps translate governance requirements into implementable controls
NIST AI RMF 1.0 — MAP	Identifying and categorizing AI risks across the system lifecycle	Leads AI-specific threat modeling; characterizes AI attack surfaces for the risk register
NIST AI RMF 1.0 — MEASURE	Quantifying AI risks and evaluating the effectiveness of controls	Specifies adversarial evaluation methods; measures control coverage against identified risks
NIST AI RMF 1.0 — MANAGE	Prioritizing and implementing risk treatment decisions	Designs and implements technical controls; owns AI-specific security architecture decisions
NIST CSF 2.0 — DE.AE	Adverse Event Analysis — detecting and analyzing security events	Ensures AI-specific attack patterns are included in threat detection capability; connects drift monitoring to security alerting

The two frameworks are complementary, not competing. NIST AI RMF addresses the AI-specific risk management lifecycle; NIST CSF 2.0 provides the broader cybersecurity function structure (IDENTIFY,

PROTECT, DETECT, RESPOND, RECOVER) into which AI security controls fit. AI Security Architects must know both and be able to map their technical work to the appropriate subcategory in both frameworks.

3. Threat Modeling for AI Systems: MITRE ATLAS v2.1

The AI Security Architect's most important activity is threat modeling — systematically identifying how AI systems can be attacked. Standard threat modeling methodologies such as STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) are necessary but insufficient for AI systems because they do not enumerate AI-specific attack categories.

MITRE ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems) v2.1 is the primary reference for AI-specific threat modeling. It catalogs adversarial tactics and techniques across the AI lifecycle:

- **Reconnaissance:** Discovering AI system details — model types, training data domains, input formats, API behaviors — through public information and systematic probing. This knowledge enables more targeted attacks.
- **Resource Development:** Building attack tools and infrastructure — adversarial example generators, model extraction frameworks, proxy datasets for training surrogate models.
- **Initial Access:** Gaining access to AI systems — compromising training infrastructure, exploiting exposed management interfaces, or obtaining API access through legitimate channels for abuse.
- **ML Model Access:** Interacting with deployed models — query-based black-box access for extraction or adversarial example development, or white-box access if model weights are obtained.
- **Impact:** Achieving attacker objectives — eroding model integrity (backdoors, poisoning), evading model detection (adversarial examples), extracting intellectual property (model extraction, membership inference), or abusing model capabilities (jailbreaking, prompt injection for LLMs).

Exam tip: STRIDE does not cover model extraction, adversarial input attacks, training data poisoning, or membership inference. For AI system threat modeling, MITRE ATLAS v2.1 is the required supplemental taxonomy. Know when to apply ATLAS (AI-specific threats) vs. STRIDE (traditional IT threats) — the exam tests this distinction.

4. Real-World Incident: Adversarial Evasion of AI-Based Network IDS (2023)

Real-World Incident — Adversarial Evasion of AI Intrusion Detection (2023): Researchers demonstrated that AI-based network intrusion detection systems could be evaded by adversarially crafted network traffic without requiring any access to the model itself. The attack worked by making malicious traffic statistically resemble benign traffic in the feature space the intrusion detection model used — crafting packet timing, size distributions, and protocol field values to match the benign traffic profile the model had learned. The detection model reported high confidence that the traffic was benign. Critically, the attacker only needed to know the feature categories the model was trained on, which could be inferred by observing what traffic the system flagged and what it did not — a reconnaissance step requiring no privileged access.

This incident illustrates three principles AI Security Architects must internalize: (1) adversarial evasion is achievable without white-box model access — black-box query-based inference is sufficient for developing effective evasion; (2) AI-based security tools are not inherently more secure than traditional tools and must themselves be subject to adversarial robustness evaluation before deployment; (3) the reconnaissance step (observing what the model flags) is a prerequisite the attacker completes through legitimate-appearing queries that security teams may not detect as adversarial activity.

5. Adversarial Robustness: Designing Against Input Attacks

One of the AI Security Architect's technical responsibilities is specifying adversarial robustness requirements and evaluating whether deployed models meet them. Adversarial robustness evaluation uses specialized toolkits and covers different attack categories depending on the model type.

Model Type	Attack Category	Evaluation Tool / Method
Image classification	Adversarial examples (FGSM, PGD, C&W attacks) — perturbed images causing misclassification	IBM Adversarial Robustness Toolbox (ART), CleverHans, Microsoft Counterfit
NLP / LLM	Prompt injection, jailbreaking, context manipulation	OWASP LLM Top 10 v1.1 (2024) test cases; red team evaluation with adversarial prompts
Classification models (general)	Boundary attacks — inputs landing just across decision boundaries	ART boundary attack implementations; ZOO attack for black-box settings
Any model served via API	Model extraction — systematic querying to reconstruct a functional model approximation	Knockoff Nets, PRADA countermeasures; rate limiting evaluation
Any model (training phase)	Data poisoning — inserting malicious samples to influence learned behavior	Poisoning detection via data provenance audit and influence function analysis

AI Security Architects do not necessarily execute these evaluations themselves — they specify requirements, commission evaluations, interpret results, and determine whether identified vulnerabilities meet the threshold for remediation before deployment. They serve as the technical bridge between security research methods and organizational risk decisions.

6. Model Privacy: Differential Privacy and Federated Learning

AI Security Architects specify privacy-preserving techniques for models trained on sensitive data. Two technologies are central to this work and tested on the SecAI+ exam.

- **Differential Privacy (DP):** Adds mathematically calibrated noise to training updates (gradients, model weights, or query responses) such that no individual training record can be reliably identified from the trained model — even by an adversary with sophisticated model inversion capabilities. Apple, Google, and Microsoft have production deployments of differential privacy in AI systems. The key tradeoff: differential privacy reduces model accuracy because the noise perturbs what the model

learns. The privacy-utility tradeoff is parameterized by epsilon — lower epsilon means stronger privacy guarantees and greater accuracy loss.

- **Federated Learning (FL):** Trains models across distributed data sources without centralizing raw data. Each participant trains locally on their data and shares only model updates (gradients or weight deltas), never underlying data. The aggregated updates are combined by a central server to produce an improved global model. Google's federated learning implementations power Gboard's next-word prediction without sending user keystrokes to Google servers. The security concern: federated learning is vulnerable to gradient inversion attacks (reconstructing training data from shared gradients) and Byzantine attacks (malicious participants submitting poisoned updates). Secure aggregation protocols address these risks.

Privacy Technique	What It Prevents	Key Tradeoff
Differential Privacy	Membership inference and model inversion attacks — prevents identifying individual training records	Accuracy loss proportional to privacy budget (epsilon); requires careful noise calibration
Federated Learning	Centralized data collection — training data never leaves participant devices or organizations	Vulnerable to gradient inversion and Byzantine attacks without additional safeguards; harder to debug
Differential Privacy + FL	Both centralized data risk and individual record inference — the strongest combination	Compound accuracy loss; requires tuning both FL aggregation and DP noise parameters

7. AI Supply Chain Security

AI systems depend on supply chains that extend considerably beyond traditional software supply chains. AI Security Architects must specify controls covering each layer of this extended supply chain.

- **Pre-trained model weights:** Models downloaded from public repositories (Hugging Face Hub, PyTorch Hub) may be backdoored or tampered. Controls: verify checksums against published values; prefer SafeTensors format over pickle-based formats; use model registries that enforce artifact signing.
- **Training datasets:** Datasets sourced from external providers or public collections may have been poisoned. Controls: document data provenance with chain-of-custody records; perform statistical validation on sourced datasets; maintain immutable versioned copies.
- **ML framework libraries:** PyTorch, TensorFlow, Hugging Face Transformers, and their dependency trees are software supply chain risks. Controls: pin dependency versions; generate SBOM (Software Bill of Materials) for each training environment; scan dependencies with tools like Safety or pip-audit.
- **MLOps tooling:** Pipeline orchestrators, experiment trackers, and model registries are part of the supply chain. Controls: use signed container images for all pipeline components; enforce least-privilege service accounts.

- Cloud AI services: Third-party APIs (OpenAI API, Azure OpenAI, Vertex AI) introduce vendor dependency and data handling risks. Controls: review service agreements for data retention and training opt-out policies; evaluate fallback options if service is unavailable.

8. Securing the AI Inference Layer

The inference layer — where models receive inputs and return outputs — is the most exposed component of most AI deployments. It is where model extraction, adversarial input, and sensitive information disclosure attacks occur. AI Security Architects specify the following controls for the inference layer:

- Authentication and authorization: API authentication using OAuth 2.0 or API keys managed through a secrets manager. Authorization ensuring that only permitted callers can access specific models. Unauthenticated inference endpoints enable model extraction attacks without any barrier.
- Rate limiting: Limits the number of requests a caller can make per unit time, preventing both model extraction (which requires thousands to millions of queries) and inference flooding (denial of service through compute exhaustion). Rate limiting should be tuned to expected legitimate usage patterns.
- Input validation: Reject malformed, oversized, or type-invalid inputs before they reach the model. For LLMs, implement prompt length limits and structural validation. Input validation does not prevent all adversarial inputs but raises the bar for exploitation.
- Output filtering: Implement filters that detect and suppress model outputs containing sensitive information — PII, training data verbatim, internal system details. This addresses OWASP LLM Top 10 v1.1 LLM06 (Sensitive Information Disclosure).
- Audit logging: Capture all inference requests (caller identity, input characteristics, response metadata, timestamp) for anomaly detection and incident response. Logs should be retained in a tamper-evident store.

OWASP LLM Top 10 v1.1 LLM06: Sensitive Information Disclosure covers cases where LLMs return sensitive data encountered during training — personal information, proprietary data, confidential documents. Output filtering at the inference layer is the primary technical control. The AI Security Architect specifies both the filter design and the sensitivity categories it must detect.

9. Red Team Perspective: What AI Red Teams Actually Do

AI red teams do not simply run standard penetration tests against AI systems — they conduct adversarial ML evaluations that require skills distinct from traditional penetration testing. AI Security Architects must understand what AI red team engagements cover to commission and evaluate them correctly.

- Model extraction: Systematically querying the inference API to reconstruct a functional approximation of the target model. The extracted model can then be used offline to develop adversarial examples more efficiently than black-box attacks allow. Rate limiting and query monitoring are the primary defenses.
- Membership inference: Determining whether specific data records were used in model training. A successful membership inference attack constitutes a privacy breach — it reveals information about the training dataset composition. Differential privacy is the primary technical defense.

- **Model inversion:** Reconstructing training data samples from model outputs — extracting sensitive information the model learned during training. For a model trained on medical records, model inversion may reconstruct identifiable patient-level information.
- **Backdoor activation testing:** Testing whether the model has hidden behaviors triggered by specific inputs (trigger patterns). Requires access to candidate triggers; more effective when combined with model weight analysis if white-box access is available.
- **Prompt injection and jailbreaking for LLMs:** Attempting to override system instructions, extract system prompts, or cause the LLM to produce prohibited content through adversarially crafted inputs. Documented in OWASP LLM Top 10 v1.1 LLM01 (Prompt Injection).

10. Incident Response Planning for AI Systems

AI Security Architects design incident response plans that address AI-specific attack scenarios not covered by standard IR playbooks. Standard playbooks do not address questions like: how do you respond when a production model has been poisoned? How do you scope a membership inference breach? How do you verify that a replacement model is clean?

- **Pulling a compromised model:** the IR plan must include a procedure for removing a compromised or backdoored model from all serving paths without causing service disruption — typically by rolling back to the previous validated version in the model registry.
- **Forensic analysis of model artifacts:** determining whether a model artifact has been tampered with requires checksum comparison against registry records, weight distribution analysis for statistical anomalies, and behavioral testing against known clean benchmarks.
- **Scoping a membership inference breach:** determining which records may have been exposed through successful membership inference requires understanding the training dataset composition and the queries the adversary executed (from inference logs).
- **GDPR notification:** if a membership inference or model inversion attack exposed EU data subjects' personal data, GDPR Article 33 requires notification to the supervisory authority within 72 hours of discovering the breach. AI Security Architects must ensure IR plans include this trigger.
- **Coordination:** AI-specific IR requires coordination between AI Security Architects, MLOps Engineers (for model rollback), data teams (for dataset forensics), legal (for regulatory notification), and traditional IR teams (for the broader infrastructure investigation).

Key Terms Glossary

Term	Definition
NIST AI RMF 1.0	NIST AI Risk Management Framework — organizes AI risk management into four functions: GOVERN, MAP, MEASURE, and MANAGE. The primary framework guiding AI Security Architects' work in the United States
MITRE ATLAS v2.1	Adversarial Threat Landscape for Artificial-Intelligence Systems — catalogs adversarial ML tactics and techniques, providing the AI-specific threat taxonomy that supplements STRIDE for AI threat modeling
Adversarial example	An input crafted with mathematically precise perturbations to cause

	a model to produce an incorrect output with high confidence. Perturbations are typically imperceptible to humans for image classifiers
Model extraction	An attack in which an adversary systematically queries a model's API to reconstruct a functional approximation, enabling offline adversarial attack development without repeated API calls
Membership inference	An attack determining whether specific data records were in the model's training dataset — a privacy breach revealing training data composition
Model inversion	An attack reconstructing training data samples from model outputs — extracting sensitive information the model learned during training
Differential Privacy (DP)	A mathematical privacy guarantee where adding calibrated noise to training updates ensures that no individual training record can be identified from the trained model, parameterized by epsilon (privacy budget)
Federated Learning (FL)	A training approach where model updates (gradients or weight deltas) are computed locally and aggregated centrally without raw training data ever leaving participant devices or organizations
IBM Adversarial Robustness Toolbox (ART)	Open-source Python library for adversarial machine learning, providing implementations of adversarial attack methods (FGSM, PGD, C&W, boundary attacks) and defenses for evaluation
SafeTensors	Model serialization format that stores only tensor data without executable code, preventing the arbitrary code execution vulnerability present in PyTorch pickle-based model files
OWASP LLM Top 10 v1.1 (2024)	Framework documenting the top ten security risks specific to Large Language Models, including prompt injection (LLM01), sensitive information disclosure (LLM06), and supply chain vulnerabilities (LLM03)
GDPR Article 33	Requires controllers to notify supervisory authorities within 72 hours of discovering a personal data breach — applies when AI system attacks (membership inference, model inversion) expose EU data subjects' personal data

Quick Revision Checklist

- AI Security Architects design security into AI systems from the beginning — not added after deployment. They are distinct from traditional security architects because AI attack surfaces require AI-specific expertise.
- NIST AI RMF 1.0 functions: GOVERN (policies + oversight), MAP (risk identification), MEASURE (quantification + evaluation), MANAGE (implementation). AI Security Architects own MEASURE and MANAGE technically.
- NIST CSF 2.0 DE.AE (Adverse Event Analysis) is where AI-specific attack patterns must be integrated into threat detection — a key responsibility of the AI Security Architect.
- MITRE ATLAS v2.1 is the AI-specific threat taxonomy — STRIDE does not cover model extraction, adversarial examples, poisoning, or membership inference. Use ATLAS for AI threat modeling.

- The 2023 adversarial evasion of AI-based IDS demonstrates that AI security tools themselves must be adversarially evaluated — black-box evasion is achievable through query-based reconnaissance.
- Adversarial robustness evaluation tools: IBM ART, CleverHans, Microsoft Counterfit. Apply the appropriate tool to the attack category and model type.
- Differential privacy adds noise to prevent membership inference and model inversion — tradeoff is accuracy loss. Federated learning prevents centralized data collection — tradeoff is vulnerability to gradient inversion and Byzantine attacks.
- AI supply chain layers: model weights, training datasets, ML framework libraries, MLOps tooling, cloud AI services. Each requires specific integrity controls.
- Inference layer controls: authentication (OAuth 2.0), rate limiting (prevents extraction and flooding), input validation, output filtering (addresses LLM06 Sensitive Information Disclosure), audit logging.
- AI red team activities: model extraction, membership inference, model inversion, backdoor activation testing, prompt injection for LLMs. Requires adversarial ML skills, not only traditional pen testing.
- GDPR Article 33: 72-hour supervisory authority notification required when AI attacks expose EU data subjects' personal data.
- Exam tip: OWASP LLM Top 10 v1.1 applies to LLM-specific risks; MITRE ATLAS v2.1 applies to the broader adversarial ML landscape across all model types. Know when to apply each.

10 Exam-Based MCQs — AI Security Architect

Test yourself after reading. These questions are written in real SecAI+ exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: An AI Security Architect is leading a threat modeling exercise for a new AI-based fraud detection system. The system trains on customer transaction histories, exposes an inference API, and uses a third-party pre-trained model as a feature extractor. Which framework should the AI Security Architect use to enumerate AI-specific attack tactics and techniques during the threat model?

- A) STRIDE — Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
- B) MITRE ATLAS v2.1 — Adversarial Threat Landscape for Artificial-Intelligence Systems
- C) OWASP Top Ten 2021 — focused on web application vulnerabilities
- D) NIST SP 800-30 — Guide for Conducting Risk Assessments

Answer: B **Explanation:** B is correct. MITRE ATLAS v2.1 is the AI-specific threat taxonomy that catalogs adversarial tactics and techniques across the AI lifecycle — reconnaissance, ML model access, model extraction, training data poisoning, adversarial examples, and impact categories. STRIDE (A) is a useful traditional threat modeling methodology but does not enumerate AI-specific attack categories such as model extraction, membership inference, or adversarial example crafting. OWASP Top Ten (C) addresses web application vulnerabilities — relevant for web-facing AI APIs but not a comprehensive AI threat taxonomy. NIST SP 800-30 (D) is a risk assessment methodology, not an attack taxonomy.

Q2. Scenario: An AI Security Architect designs and oversees a red team exercise in which adversarial ML practitioners attempt model extraction, membership inference, and backdoor activation testing against the organization's deployed AI systems, producing a scored assessment of each system's robustness.

Which NIST AI RMF 1.0 function does this activity MOST directly fall within?

- A) GOVERN — establishing policies and accountability structures for AI risk
- B) MAP — identifying and categorizing AI risks
- C) MEASURE — quantifying AI risks and evaluating control effectiveness
- D) MANAGE — prioritizing and implementing risk treatment decisions

Answer: C **Explanation:** C is correct. Designing and executing adversarial robustness evaluations — systematically testing how well security controls withstand identified attack scenarios — is the MEASURE function of NIST AI RMF 1.0, which covers quantifying AI risks and evaluating the effectiveness of controls against them. A (GOVERN) covers establishing the governance structures, policies, and oversight mechanisms for AI risk — a prerequisite for evaluation but not the evaluation activity itself. B (MAP) covers identifying and categorizing risks — the threat modeling step that precedes evaluation. D (MANAGE) covers prioritizing risks and implementing treatment decisions based on measurement results — the step that follows evaluation.

Q3. Scenario: A healthcare organization is training an AI model on patient records to predict readmission risk. The CISO is concerned about membership inference attacks that could reveal whether specific patients were in the training dataset. The security team is recommending differential privacy for the training process. What is the PRIMARY tradeoff the business must accept?

- A) Differential privacy requires that model weights be stored in SafeTensors format, which is incompatible with the organization's current model serving infrastructure
- B) Differential privacy prevents the model from being deployed in federated learning configurations
- C) Differential privacy reduces model accuracy because the calibrated noise added to training updates perturbs what the model learns
- D) Differential privacy requires that training be performed on-premises rather than in cloud environments to comply with data residency requirements

Answer: C **Explanation:** C is correct. Differential privacy adds mathematically calibrated noise to training updates to ensure that no individual training record can be identified from the trained model. This noise perturbs the gradient signal during training, reducing model accuracy — the privacy-utility tradeoff. The magnitude of accuracy loss is proportional to the privacy budget (epsilon); stronger privacy guarantees require more noise and more accuracy loss. A is incorrect — differential privacy is about training noise, not model serialization format. B is incorrect — differential privacy can be combined with federated learning (federated learning with DP is the strongest combination described in the lecture). D is incorrect — differential privacy is a mathematical property of the training algorithm, not a data residency control.

Q4. Which inference layer control MOST directly addresses the OWASP LLM Top 10 v1.1 LLM06 risk?

- A) Rate limiting on the inference API to prevent model extraction through volume attacks
- B) OAuth 2.0 authentication ensuring only authorized callers access the model

- C) Output filtering to detect and suppress model responses containing sensitive information
- D) Input validation rejecting prompts exceeding the maximum token length

Answer: C **Explanation:** C is correct. OWASP LLM Top 10 v1.1 LLM06 (Sensitive Information Disclosure) covers cases where LLMs return sensitive data encountered during training — PII, proprietary data, confidential internal documents. Output filtering at the inference layer is the primary technical control that detects and suppresses these outputs before they reach the caller. A (rate limiting) addresses model extraction (LLM10) and denial of service — not sensitive information disclosure. B (OAuth 2.0 authentication) ensures authorized access but does not prevent an authorized caller from receiving sensitive information in model outputs. D (input validation) rejects malformed inputs — useful for prompt injection defense (LLM01) but not for filtering sensitive outputs.

Q5. Which of the following is the MOST significant difference between an AI red team engagement and a traditional penetration test?

- A) AI red teams require government clearance to conduct adversarial testing on AI systems used in regulated industries
- B) AI red teams conduct adversarial ML evaluations (model extraction, membership inference, backdoor testing) requiring skills that traditional penetration testers do not typically have
- C) Traditional penetration tests are more expensive than AI red team engagements because they cover a wider attack surface
- D) AI red teams focus exclusively on the model training infrastructure while traditional penetration tests cover the inference API

Answer: B **Explanation:** B is correct. AI red team engagements require adversarial ML skills — understanding of how to develop adversarial examples, execute model extraction attacks, perform membership inference, and test for backdoor triggers — that are distinct from traditional penetration testing skills. A traditional penetration tester may be highly skilled at network exploitation, web application attacks, and privilege escalation but may have no framework for analyzing AI-specific attack surfaces. A (government clearance) is factually incorrect. C (cost comparison) is not discussed in the lecture and is not a meaningful distinguishing characteristic. D is incorrect — AI red teams cover both training infrastructure and inference API, as well as the model itself; neither AI nor traditional pen tests are limited to one of these layers.

Q6. Which framework applies MOST specifically to prompt injection attacks against an LLM-based customer service chatbot?

- A) MITRE ATLAS v2.1, which covers the full adversarial ML landscape across all model types
- B) OWASP LLM Top 10 v1.1 (2024), which covers LLM-specific risks including prompt injection as LLM01
- C) NIST SP 800-53 Revision 5, which provides general security control families for information systems
- D) STRIDE, which covers the Tampering category applicable to manipulated model inputs

Answer: B **Explanation:** B is correct. OWASP LLM Top 10 v1.1 (2024) is the framework specifically

designed to address LLM-specific security risks. LLM01 (Prompt Injection) directly covers the attack scenario described — adversarially crafted inputs designed to override system instructions or manipulate LLM behavior. While MITRE ATLAS v2.1 (A) covers a broader adversarial ML landscape, OWASP LLM Top 10 is the more specific and directly applicable framework for LLM prompt injection. NIST SP 800-53 (C) provides general control families not specific to LLM attacks. STRIDE (D) categorizes tampering broadly but does not provide specific guidance on LLM prompt injection techniques or defenses.

Q7. What is the PRIMARY security rationale for preferring SafeTensors format over PyTorch's native pickle-based .pt format for model artifact storage?

- A) SafeTensors files are compressed more efficiently, reducing storage costs for large model artifacts
- B) SafeTensors is a cross-framework format that enables models trained in PyTorch to be served by TensorFlow infrastructure
- C) SafeTensors stores only tensor data without executable code, preventing arbitrary code execution that occurs when loading malicious pickle-format model files
- D) SafeTensors files cannot be tampered with post-signing because the format includes built-in cryptographic integrity verification

Answer: C **Explanation:** C is correct. PyTorch's native serialization format uses Python's pickle module, which executes deserialization code without restriction during model loading. A malicious actor can craft a .pt file that contains a pickle payload executing arbitrary code — establishing a reverse shell, exfiltrating data, or modifying the model in memory — when the file is loaded. SafeTensors was designed specifically to prevent this: it stores only tensor data in a flat binary format with no ability to embed executable code. A (compression efficiency) is not the primary security rationale. B (cross-framework compatibility) is a feature of ONNX, not the primary purpose of SafeTensors. D (built-in cryptographic integrity) is not a feature of SafeTensors itself — integrity verification requires external signing.

Q8. *Scenario:* A financial institution discovers that an adversary successfully executed a membership inference attack against their AI credit-scoring model, likely revealing whether specific EU customer records were in the training dataset. Under which regulatory requirement must the organization notify the relevant supervisory authority within 72 hours?

- A) NIST AI RMF 1.0 MANAGE function — requires notification of all AI security incidents to NIST
- B) EU AI Act Article 5 — prohibits the use of AI for certain high-risk applications
- C) GDPR Article 33 — requires supervisory authority notification within 72 hours of discovering a personal data breach
- D) ISO/IEC 42001:2023 — requires annual AI system audit reports to be submitted to the certifying body

Answer: C **Explanation:** C is correct. GDPR Article 33 requires data controllers to notify the competent supervisory authority within 72 hours of becoming aware of a personal data breach — and a successful membership inference attack that exposes whether EU data subjects' records were in a training dataset constitutes a personal data breach under GDPR. A (NIST AI RMF MANAGE) is a risk management framework, not a regulatory reporting requirement, and NIST does not receive incident notifications. B (EU

AI Act Article 5) prohibits specific high-risk AI applications but does not specify a 72-hour breach notification requirement. D (ISO/IEC 42001:2023) is a management system standard with certification and audit requirements — it does not specify a 72-hour breach notification.

Q9. An AI Security Architect is reviewing a federated learning implementation for a cross-hospital AI model. Which attack is the federated learning architecture MOST vulnerable to that would NOT affect a centralized training approach?

- A) Model inversion attacks reconstructing training data from model outputs
- B) Byzantine attacks where malicious participants submit poisoned gradient updates to corrupt the global model
- C) Membership inference attacks determining whether specific patient records were in the training dataset
- D) Model extraction attacks where adversaries systematically query the inference API

Answer: B **Explanation:** B is correct. Byzantine attacks — where one or more federated learning participants submit malicious gradient updates designed to corrupt the aggregated global model — are specific to federated learning architectures because they exploit the distributed aggregation mechanism. In a centralized training approach, the training process is under the control of a single operator with full visibility into the training data and updates. Federated learning distributes that control to participants who may be malicious. A (model inversion) applies to any model regardless of training architecture. C (membership inference) applies to any trained model and is actually one of the concerns federated learning is meant to partially address. D (model extraction) targets the inference API — not affected by whether training was federated or centralized.

Q10. Which of the following BEST describes the AI Security Architect's responsibility regarding AI systems with ethically problematic use cases?

- A) The AI Security Architect's responsibility is limited to technical security — ethical concerns are outside their professional scope
- B) The AI Security Architect should implement security controls as requested and document any ethical concerns in a footnote to the architecture document
- C) The AI Security Architect has a professional responsibility to raise ethical concerns, decline to design security for applications violating applicable law, and document concerns formally when overridden by business stakeholders
- D) Ethical concerns are resolved by the CISO — the AI Security Architect should escalate immediately and await direction without taking any independent position

Answer: C **Explanation:** C is correct. The lecture explicitly states that AI Security Architects have a responsibility that extends beyond technical security: they must raise concerns about AI system use cases that violate ethical principles or regulatory requirements, decline to design security for applications that violate applicable law (EU AI Act Article 5 prohibitions, for example), and document concerns formally when business stakeholders override security recommendations. A security architect who designs robust security for a harmful AI application makes it more harmful by making it harder to detect and challenge. A (purely technical scope) conflicts with the lecture's explicit position. B (footnote documentation) is

inadequate — formal documentation and raising concerns with stakeholders are required. D (escalate without independent position) mischaracterizes the AI Security Architect's professional accountability.